

SMART CONTRACT SECURITY REVIEW

Richie-Finance

One-pass adversarial assessment

6	2	75
CONFIRMED FINDINGS	MANUAL REVIEW LEADS	CONFIDENCE FLOOR

PASHOV SOLIDITY AUDITOR WORKFLOW

Audit revision aebf06f | Management responses through b17bc6e

One-pass AI-assisted adversarial review | 12 specialist security lenses

Source revision aebf06f

2 November 2026

Review summary

CONFIRMED FINDINGS	MANUAL REVIEW LEADS
6	2

Scope

Mode	default
Confidence threshold (1-100)	75

Files reviewed

./contracts/tomb/Boardroom.sol

./contracts/tomb/Farm.sol

./contracts/tomb/GenesisRewardPool.sol

./contracts/tomb/Oracle.sol

./contracts/tomb/Peg.sol

./contracts/tomb/PegRedeem.sol

./contracts/tomb/RebateCompositeOracle.sol

./contracts/tomb/Rebates.sol

./contracts/tomb/Share.sol

./contracts/tomb/Treasury.sol

./contracts/tomb/Zap.sol

Findings at a glance

#	Confidence	Title
1	90	Split deposits avoid every configured deposit fee
2	90	A negative rebase lets the first Genesis withdrawer take every token
3	90	Taxed tokens make every Genesis exit fail
4	90	A negative rebase lets the first Farm withdrawer take every token
5	90	Taxed tokens make every Farm exit fail
6	90	Missed epochs pay past rewards to current stakers

FINDING 01 INFORMATIONAL CONFIDENCE 90

Split deposits avoid every configured deposit fee

`GenesisRewardPool.deposit`

DESCRIPTION

An attacker can split a coarse-token deposit into small calls that round every fee to zero and keep the full fee.

RECOMMENDED FIX

```
+import {Math} from "@openzeppelin/contracts/utils/math/Math.sol";

-uint256 fee = (received * pool.depositFeeBps) / BPS;
+uint256 fee = Math.mulDiv(
+    received,
+    pool.depositFeeBps,
+    BPS,
+    Math.Rounding.Ceil
+);
```

RICHIE FINANCE RESPONSE

INFORMATIONAL

The minimum supported pool-token precision is six decimals. At six decimals or above, exploiting fee-floor rounding requires dust-sized deposits and a prohibitive number of transactions. Richie Finance does not consider the issue economically profitable under the supported pool policy.

Management response - 2 November 2026

FINDING 02 OPERATIONALLY MITIGATED CONFIDENCE 90

A negative rebase lets the first Genesis withdrawer take every token

`GenesisRewardPool.withdraw`

DESCRIPTION

After a negative rebase, the first Genesis withdrawer takes all tokens left in the pool, so later stakers lose their principal.

RECOMMENDED FIX

```
-user.amount += credited;
-pool.totalStaked += credited;
+uint256 shares = pool.totalStaked == 0
+    ? credited
+    : Math.mulDiv(credited, pool.totalStaked, balanceBefore);
+user.amount += shares;
+pool.totalStaked += shares;

-pool.token.safeTransfer(sender, _amount);
+uint256 assets = Math.mulDiv(
+    _amount,
+    pool.token.balanceOf(address(this)),
+    pool.totalStaked
+);
+pool.token.safeTransfer(sender, assets);
```

RICHIE FINANCE RESPONSE OPERATIONALLY MITIGATED

No negative-rebase token will be listed in either GenesisRewardPool or ShareRewardPool. Richie Finance accepts this finding under that pool-listing restriction.

Management response - 2 November 2026

FINDING 03 FIXED CONFIDENCE 90

Taxed tokens make every Genesis exit fail

`GenesisRewardPool.withdraw`

DESCRIPTION

A taxed pool token credits its net deposit, but both Genesis exits require the user to receive the larger recorded amount.

RECOMMENDED FIX

```
uint256 received = pool.token.balanceOf(address(this)) - balanceBefore;
+require(received == _amount, "GenesisPool: unsupported token");
 uint256 fee = (received * pool.depositFeeBps) / BPS;
```

RICHIE FINANCE RESPONSE FIXED

The recipient exact-balance checks were removed in commit b17bc6edc0ebd5512dce352ac61728970ef4c030, while the pool-debit checks remain. Taxed tokens will not be listed in Genesis or Farm pools regardless.

Management response - 2 November 2026

FINDING 04 OPERATIONALLY MITIGATED CONFIDENCE 90

A negative rebase lets the first Farm withdrawer take every token

`ShareRewardPool.withdraw`

DESCRIPTION

After a negative rebase, the first Farm withdrawer takes all tokens left in the pool, so later stakers lose their principal.

RECOMMENDED FIX

```
-user.amount += received;
-pool.totalStaked += received;
+uint256 shares = pool.totalStaked == 0
+    ? received
+    : Math.mulDiv(received, pool.totalStaked, balanceBefore);
+user.amount += shares;
+pool.totalStaked += shares;

-pool.token.safeTransfer(sender, _amount);
+uint256 assets = Math.mulDiv(
+    _amount,
+    pool.token.balanceOf(address(this)),
+    pool.totalStaked
+);
+pool.token.safeTransfer(sender, assets);
```

RICHIE FINANCE RESPONSE OPERATIONALLY MITIGATED

No negative-rebase token will be listed in either GenesisRewardPool or ShareRewardPool. Richie Finance accepts this finding under that pool-listing restriction.

Management response - 2 November 2026

FINDING 05 FIXED CONFIDENCE 90

Taxed tokens make every Farm exit fail

`ShareRewardPool.withdraw`

DESCRIPTION

A taxed pool token credits its net deposit, but both Farm exits require the user to receive the larger recorded amount.

RECOMMENDED FIX

```
uint256 received = pool.token.balanceOf(address(this)) - balanceBefore;
+require(received == _amount, "ShareRewardPool: unsupported token");
 user.amount += received;
 pool.totalStaked += received;
```

RICHIE FINANCE RESPONSE FIXED

The recipient exact-balance checks were removed in commit b17bc6edc0ebd5512dce352ac61728970ef4c030, while the pool-debit checks remain. Taxed tokens will not be listed in Genesis or Farm pools regardless.

Management response - 2 November 2026

FINDING 06 INTENDED BEHAVIOR / ACCEPTED RISK CONFIDENCE 90

Missed epochs pay past rewards to current stakers

`Treasury.allocateSeigniorage`

DESCRIPTION

A new sole staker can execute every missed epoch in consecutive blocks, take all past allocations, and satisfy four-epoch locks within minutes.

RECOMMENDED FIX

```
modifier checkEpoch() {
+    uint256 dueEpoch = (block.timestamp - startTime) / PERIOD;
     require(block.timestamp >= nextEpochPoint(), "Treasury: not opened yet");
+    epoch = dueEpoch;
     _;
-    epoch += 1;
+    epoch = dueEpoch + 1;
 }

-members[msg.sender].epochTimerStart = treasury.epoch();
+members[msg.sender].epochTimerStart = block.timestamp;

-members[member].epochTimerStart + withdrawLockupEpochs <= treasury.epoch()
+members[member].epochTimerStart + withdrawLockupEpochs * 6 hours <= block.timestamp
```

RICHIE FINANCE RESPONSE

INTENDED BEHAVIOR / ACCEPTED RISK

The protocol intentionally catches up missed epochs. A keeper bot is expected to call the epoch update every six hours, and eligible users can also trigger the public update from the website staking page. Richie Finance considers multiple outstanding epochs unlikely under this operating model and accepts the residual risk which does not pose risk to user funds.

Management response - 2 November 2026

Manual review leads

These trails contain concrete code smells, but this pass did not complete an end-to-end exploit path.

LEAD 01

Composite quotes multiply TWAPs from different windows

`RebateCompositeOracle.consult`

Code smells: different source periods, different timestamps, product of arithmetic TWAPs - An attacker can desynchronize the two TWAP windows, but this pass did not prove that the rebate exceeds the manipulation cost.

LEAD 02

ERC20 bonds lack a minimum Share output

`RebateTreasury.bond`

Code smells: branch asymmetry, no `minShareOut`, mutable TWAP quote - An oracle update can reduce an ERC20 bonder's Share output before inclusion, but this pass did not prove a profitable attacker exit.

Review limitation

This review was performed by an AI assistant. AI analysis cannot verify the complete absence of vulnerabilities and gives no security guarantee. Team reviews, bug bounties, and on-chain monitoring remain strongly recommended.

Consultation: https://www.pashov.com

REVIEW PROVENANCE

Audit methodology & source links

Pashov Solidity Auditor workflow | Richie Finance

400+	4,000+	$100B+	50+
AUDITS	VULNERABILITIES	TVL SECURED	RESEARCHERS

Figures reported by Pashov Audit Group at pashov.com

Why this workflow

This review used the open-source Pashov Solidity Auditor workflow, applying twelve specialist lenses across precision, access control, economics, execution, invariants, protocol boundaries, trust assumptions, numerical gaps, and asset flows.

Industry context

Pashov Audit Group publishes an extensive Solidity security track record and lists leading DeFi protocols among its clients. Richie Finance used the open-source workflow; this review was not performed or endorsed by Pashov Audit Group.

ONE-PASS REVIEW PIPELINE

01 SOURCE FREEZE
11 production contracts at audit revision aebf06f

>

02 12 SECURITY LENSES
Consolidated across three available runtime agents

>

03 GATED FINDINGS
Confidence floor 75 plus management responses

Execution record

AUDIT PASS	1 pass
AUDIT REVISION	aebf06f
RESPONSES THROUGH	b17bc6e
RUNTIME	Client-provided: "used recommended GPT-5.6 SOL for this task"

Pashov Skills
Open-source security workflow
OPEN LINK ->

Pashov Audit Group
Auditor profile and track record
OPEN LINK ->

Richie Contracts
Reviewed Solidity repository
OPEN LINK ->

AI-assisted review limitation: this report does not guarantee the absence of vulnerabilities and is not a substitute for an independent manual audit, a bug bounty, testing, monitoring, or operational controls.